

Firmware 7.15 combined blocks 8–10 local audit

Local software checks pass on the frozen candidate below; combined audit closure remains pending. Block 10 is implemented and locally verified; current block 8 and block 9 source snapshots are integrated and audited, including one additional account-slot repair. Agent1's and agent2's final completion/handoff are still pending in the canonical ledger. Later source changes require reconciliation before final stack acceptance. No Copilot request was sent by this agent and no such request is authorized.

1. Identity and frozen scope

Reviewer: Codex agent3, 2026-09-27 UTC. Repository: /private/tmp/kk715-stack10-agent3; branch: audit/715-stack08-10-agent3-integration. The original block 10 branch remains audit/715-stack10-agent3-20260927 at bb3766bdf.

Identity	Immutable value
Complete combined base, accepted 7b	2483977523d9b6beab52a69429ace9aeefd00f76
Agent1 block 8 input	68f0b18247b469caf7b9fa86de39383b2b1b33f6
Agent2 block 9 input	2c37cce7f777f3282a4f0c8ad9dc7712a734a44c
Block 10 implementation	7e9fd56c6a0256e48fc0b1166d520c87cd1eb0cb
Integrated code before slot repair	c48e66c4f3ec427cb2e783deef065a48f111fdce
Validated integrated code	6309633ec6eb9a6a64e8173dff949c3f8e1c5166
Python companion	41af909341965c81b8afadd38f299d6f929089af
Build image	sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2
Evidence archive SHA256	d4c99db7114bec9fc74cdca18d54bd96e5c2bbd47c2b775afcf3c8327e76707

The merges preserve both agents' ancestry and do not modify their worktrees. Agent2's input was based on block 8 5037e7f24; this integration also includes agent1's later immutable-waiver repair. Historical PR #840 remains the old block 10 source, not this integrated candidate. No new PR or remote branch was published. Fork develop, release products and physical devices were untouched.

Scope: block 8 embedded replay/test/report boundaries, block 9 authenticator identity/consent/storage and numeric boundaries, block 10 EVM amount/identity review and preserved typed-array dimensions. Required variants are full and Bitcoin-only. Full 64-bit HOTP support, deferred ERC-7730 features and physical release qualification are excluded; no storage format changes were introduced.

2. Complete source reconciliation and preservation

Reviewed every non-receipt path in block 8 from accepted 7b: five embedded wire contracts, walker chunk bounds and pass counting, effective-equivalent duplicate protocol-option removal, report waiver/name controls, immutable waiver authority, required Git history and local preflight fixes. Block 8 changes no firmware runtime or Python production library. Its 39 predecessor runtime test bodies are preserved; the new controls challenge byte replay, definition identity, chunk boundaries and cancellation. All execute in the combined full suite.

Reviewed block 9 authenticator source and callers, Ping enum/error mapping, native assertions, Python wire tests and report enforcement. Two original native tests only change secret length and confirmation count to follow the selected minimum/two-screen policy; their revocation/refusal assertions survive. Tests cover exact identities, bounds, cancellation, persistence, legacy duplicate removal and independent HOTP. Agent2's decimal-only uint32 OTP counter and 0..30 second remainder checks supersede the initial INT-09-001 observation: high counters are explicitly refused instead of truncated. This is a compatibility limit, not a claim of general 64-bit HOTP support.

Block 10's seven historical paths, caller trace, raw-value and address binding, account-transfer fallback, inherited array implementation, equivalent inputs, negative controls and all 74 predecessor test identities are mapped in 715-10-audit-20260927.md and 715-10-reconciliation-20260927.json. Four native cases and seven wire contracts were added; no predecessor test names removed. The two migrated assertions now require raw review while retaining non-alias protection. The Python delta from the block 8 pin to the combined pin touches only authenticator tests and report validation; existing EVM tests are unchanged.

3. Integration finding and security closure

INT-09-002: after the OTP parser repair, getAuthAccount still parsed unchecked text with strtol and cast it to uint8_t. Empty text, suffixes and 256 could select slot 0. This is a second entry path of the numeric-boundary class. The actual Ping regression fails against c48e66c4f, receiving Success instead of Failure. No PIN/passphrase bypass or secret-key disclosure is claimed.

Contract element	Evidence
Input and state	Host-supplied slot text; account identity in encrypted storage/cache.
Observer, variants and phase	Authenticated host, both products, account-listing Ping after existing PIN/passphrase checks.
Allowed/forbidden outputs	Valid 0..9 may return the exact account or Account not found. Invalid text must return Slot request out of range, with no Success/account identity or ButtonRequest.
Equivalent representations	Empty, sign, whitespace, suffix, colon, uint8-wrap and large overflow; valid first/last slots remain distinct.

Contract element	Evidence
Repair	Reuse checked parser with AUTHDATA_SIZE-1 before lookup; null guard for direct C entry. No changes to authorization, persistence or storage format.
Executed assertions	Authenticator.AccountSlotRejectsNumericAliasesBeforeLookup and TestAuthenticatorSlotIntegration.test_account_slot_text_cannot_wrap_or_ignore_suffixes pass in full/BTC. Each wire refusal is followed by unchanged successful slot-0 lookup.
Falsification	Before-code wire test fails on the original malformed slot acceptance. Native null/bounds checks and both real transport variants pass after repair.

The integration repair is separate commit 6309633ec. Agent2 can cherry-pick its source/test changes from this repository; their worktree was left untouched. No further firmware runtime defect was confirmed in this finite pass. Agent1's later review reports six findings on this block 8 input, involving waiver authority, skip reasons and preflight. Its uncommitted repairs are not pulled or qualified here; report/preflight audit closure remains open.

4. Verification, artifacts and limits

Check on 6309633ec and pinned Python	Result	Evidence/limit
Full native	669 firmware, 19 board, 18 crypto pass	final-native-full.xml and companion board/crypto XML; fresh flash.
Bitcoin-only native	143 firmware, 19 board, 18 crypto pass	final-native-btc.xml and companion board/crypto XML; fresh flash.
Full host and added wire contracts	838 pass, 84 skip, zero failures/errors	final-host-full.xml; includes block 8 runtime, block 9 boundaries, block 10 and slot integration.
Bitcoin-only host	365 pass, 557 skip, zero failures/errors	final-host-btc.xml; EVM tests skip after explicit product assertion; auth/slot contracts execute.
Storage boot/upgrade	Five formerly unavailable executable-dependent checks now run	KK_EMULATOR_BIN points to the exact variant; no silent evidence substitution.
ARM and SRAM	Both links and budget gates pass	Full reserve 17,800 B, BTC 39,136 B; largest frame 7,664 B.
Report gates	14 regression tests and actual 2,730 full/BTC JUnit records accepted	final-case-gate.json; per-variant merged JUnit validators pass. Raw count includes both variants and is not unique test coverage.
Preflight	All Stage-1 mirrors pass	integration-preflight.log; CI clang-format 20 and Ubuntu 24.04 cppcheck.
Review-diff gate	Code-bearing; empty range rejects with exit 2	code-bearing.log and negative control. No external review requested.
EVM OLED	All five unique maximum-approval screens inspected	Prior isolated block 10 capture carried forward: Ethereum/renderer code unchanged by integration. Eight captures include three duplicate pages. All addresses and 78 amount digits are visible.

Evidence bundle: 715-08-10-local-evidence-20260927.tgz, with 100 hashed files plus manifest. It includes positive/negative XML, build logs, source/pin and image identity, package versions, scripts, SRAM output, screenshots and skip ledgers. final-skips-full.json and final-skips-btc.json enumerate every skip. Owned block 8/9/10 behavior executes on full; auth executes on both products. Remaining skips include intended BTC exclusions, deferred capabilities, disabled legacy endpoints, dylib-specific suites, emulator timer limitations and session power-cycle tests lacking process-discovery support. These are not represented as passing or physical-device evidence.

The broad pre-integration counts in the block 10 report are preserved as a different run. Final combined results above are newly executed on the frozen code/pin. Initial infrastructure/setup failures and the two migrated native expectations are described there. Supplying only host XML to the report validator correctly failed for missing native cases; merging the actual native/host XML satisfies it. No expected test result was fabricated to satisfy a report gate.

5. Report render and final inventory

Report source and PDF are generated together and visually inspected. Inventory covers the complete combined range from accepted 7b, including all reports, PDFs, evidence, tests, source, workflow and dependency changes. The report predecessor recorded below is immutable; the containing documentation head is recorded in the handoff and canonical claim. Later commits change only audit receipts; passing code/pin evidence is carried with that explicit qualification.

Inventory predecessor: 691d9b0db2537d734283695690cd4791cf945e36.

<!-- inventory:start -->

Added	Deleted	Path
9	2	.github/workflows/ci.yml
1	1	deps/python-keepkey
193	0	docs/release/audit-units/715-08-10-integration-20260927.md

Added	Deleted	Path
112	0	docs/release/audit-units/715-08-10-integration-20260927.pdf
-	-	docs/release/audit-units/715-08-10-local-evidence-20260927.tgz
97	0	docs/release/audit-units/715-08-audit-20260927.md
-	-	docs/release/audit-units/715-08-audit-20260927.pdf
-	-	docs/release/audit-units/715-08-local-evidence-20260927.tgz
138	0	docs/release/audit-units/715-08-reconciliation-20260927.json
86	0	docs/release/audit-units/715-09-audit-20260927.md
-	-	docs/release/audit-units/715-09-audit-20260927.pdf
-	-	docs/release/audit-units/715-09-local-evidence-20260927.tgz
67	0	docs/release/audit-units/715-09-reconciliation-20260927.json
163	0	docs/release/audit-units/715-10-audit-20260927.md
112	0	docs/release/audit-units/715-10-audit-20260927.pdf
73	0	docs/release/audit-units/715-10-intake-20260927.md
48	0	docs/release/audit-units/715-10-reconciliation-20260927.json
2	0	include/keepkey/firmware/authenticator.h
4	0	include/keepkey/firmware/ethereum.h
0	1	include/keepkey/transport/messages-osmosis.options
0	4	include/keepkey/transport/messages-solana.options
113	79	lib/firmware/authenticator.c
53	13	lib/firmware/ethereum.c
1	0	lib/firmware/fsm_msg_common.h
16	9	lib/firmware/fsm_msg_ethereum.h
14	0	scripts/emulator/python-keepkey-tests.sh
36	0	scripts/emulator/test_stack09_integration.py
141	0	scripts/emulator/test_stack10_regressions.py
47	2	scripts/generate-test-report.py
117	0	scripts/preflight.sh
177	0	scripts/test_generate_test_report.py
214	4	unittests/firmware/authenticator.cpp
64	0	unittests/firmware/eip712_stream.cpp
110	6	unittests/firmware/ethereum.cpp

<!-- inventory:end -->

6. Independent status and handoff

Local software verification checkpoint recorded by Codex agent3, 2026-09-27 UTC, at code 6309633ec with Python 41af9093. Implementation, targeted behavior, combined native/host/resource checks, adversarial controls and finding disposition for block 10 and INT-09-002 pass. Block 8 report/preflight findings remain open for integration. Report/skip limitations are explicit. No physical-device checks or hosted CI execution on this combined head are claimed.

Agent1's exact input CI 36302640527 passed, but its review ledger records six further findings and an active two-unit repair; final completion is pending. Agent2's documentation/evidence checkpoint 5bc9ecbba is now merged; its final combined handoff remains pending. That checkpoint changes no source or pin, so validation on 6309633ec carries forward unchanged. Reconcile any later source/pin change before final stack acceptance; documentation-only changes may carry unchanged-code evidence. Local audit of these inputs does not declare either agent's overall task complete.

External review requests from this agent: zero. Copilot remains expressly unauthorized. No PR publication, product promotion, develop merge or release.